

SOC Incident Investigation Report

Field	Value
Project	Project 03 - SOC Incident Investigation
Report type	Portfolio Demonstration – Simulated Incident
Version	v1.0
Date	2026-07-02
Author	Juan Martinez
Scenario	Phishing-based compromise against a fictional healthcare organization

Portfolio Demonstration Notice

Portfolio Demonstration – Simulated Incident

This project is a Portfolio Demonstration. It is a synthetic case study created for a cybersecurity consulting portfolio. It does not represent paid client work, employment history, or testing performed for a real organization unless explicitly stated.

No live third-party systems were tested. No real client names, production IP addresses, credentials, proprietary data, or sensitive information are included.

All Indicators of Compromise, logs, hashes, domains, IP addresses, usernames, hostnames, email headers, and evidence artifacts in this report are simulated for the case study unless explicitly marked as a public reference.

Revision History

Version	Date	Changes
v1.0	2026-07-02	Initial published portfolio version

1. Cover Page

Report title: SOC Incident Investigation Report

Case type: Portfolio Demonstration – Simulated Incident

Fictional organization: Northstar Care Group, a modeled outpatient healthcare provider

Incident class: Phishing, malicious attachment execution, attempted credential theft, and attempted lateral movement

Incident status: Contained and recovered

Ransomware outcome: Not deployed

Primary audience: Leadership, IT operations, security operations, incident responders, and compliance

stakeholders

Portfolio purpose: Demonstrate professional SOC investigation, DFIR reasoning, incident response documentation, and executive communication.

2. Executive Summary

This report documents a simulated phishing-based compromise against Northstar Care Group, a fictional healthcare organization created for a portfolio demonstration. The scenario models an employee opening a malicious attachment, PowerShell execution from Microsoft Office, attempted credential theft, attempted lateral movement, SOC detection, and rapid incident response.

The highest-risk activity was suspicious PowerShell execution followed by attempted access to credential material and failed SMB authentication against a file server. The simulated attacker did not deploy ransomware, did not gain domain administrator privileges, and did not access electronic health record data in the modeled scenario.

The incident was detected through correlated EDR and SIEM alerts: Microsoft Office spawned PowerShell with encoded parameters, PowerShell attempted external network access, and endpoint telemetry showed suspicious LSASS access behavior. The SOC contained the endpoint, disabled the affected user’s active sessions, blocked simulated infrastructure indicators, and started incident response within the same business day.

Business impact was limited because response actions occurred before successful lateral movement or ransomware deployment. Recommended next steps are to strengthen attachment detonation, restrict Office child processes, improve PowerShell controls, accelerate endpoint isolation procedures, and tune detection logic for credential theft and lateral movement attempts.

3. Incident Overview

Item	Detail
Incident ID	SIM-IR-2026-003
Incident type	Phishing-based endpoint compromise
Organization	Northstar Care Group, fictional healthcare organization
Affected user	SIMULATED: ncare\emiller
Affected workstation	SIMULATED: NCG-WKS-014
Initial vector	SIMULATED: Malicious Excel attachment delivered by email
First alert time	SIMULATED: 2026-06-24 09:18:44 EDT
Containment time	SIMULATED: 2026-06-24 10:04:21 EDT
Overall severity	High
Final status	Contained, eradicated, and recovered

Table 1: Incident overview

The incident represents a realistic but synthetic SOC case. The attacker attempted to move from initial access toward credential theft and lateral movement, but endpoint isolation and account containment interrupted the chain before ransomware deployment or broad compromise.

4. Environment Description

Northstar Care Group is a fictional healthcare provider modeled with common business systems and security tooling. The environment description is included only to make the incident analysis readable and does not describe a real organization.

Asset	Role	Notes
SIMULATED: NCG-WKS-014	Windows 11 workstation	Affected employee endpoint
SIMULATED: NCG-DC-01	Windows domain controller	Authentication and Group Policy
SIMULATED: NCG-FS-02	File server	Department file shares
SIMULATED: mail.northstar-care.example	Email tenant namespace	Example domain for simulated mail flow
SIMULATED: siem-01	SIEM platform	Central alerting and log review
SIMULATED: edr-console-01	EDR console	Endpoint telemetry and isolation

Table 2: Simulated environment summary

Security layer	Modeled capability
Email security	Attachment scanning, sender reputation, URL rewriting, quarantine
Endpoint security	EDR process telemetry, malware prevention, host isolation
Identity controls	Active Directory, conditional access, password reset workflow
Logging	Windows Security, PowerShell, Sysmon, Defender, DNS, proxy, and VPN logs
Incident response	SOC triage, containment playbook, evidence preservation, recovery validation

Table 3: Modeled security capabilities

5. Timeline of Events

Time	Event	Source	Analyst assessment
2026-06-24 08:52:13 EDT	SIMULATED: emiller receives email with attachment Q2_Patient_Billing_Adjustments.xlsm	Email security log	Initial phishing delivery
2026-06-24 09:12:37 EDT	Attachment opened from Outlook cache	EDR process telemetry	User execution
2026-06-24 09:13:02 EDT	Excel spawns PowerShell with hidden window and encoded parameter	Sysmon Event ID 1	Suspicious Office child process
2026-06-24 09:13:18 EDT	PowerShell connects to SIMULATED: updates-careportal.example	DNS and proxy log	Simulated command retrieval attempt
2026-06-24 09:14:41 EDT	Suspicious access attempt against LSASS observed	EDR alert	Attempted credential theft
2026-06-24 09:16:09 EDT	Failed SMB logons against SIMULATED: NCG-FS-02	Windows Security Event ID 4625	Attempted lateral movement
2026-06-24 09:18:44 EDT	SIEM correlation rule triggers high severity incident	SIEM alert	Detection confirmed
2026-06-24 09:28:10 EDT	SOC analyst escalates to incident response	Case management	Response initiated
2026-06-24 09:42:33 EDT	Affected user sessions revoked and password reset started	Identity audit log	Account containment
2026-06-24 10:04:21 EDT	SIMULATED: NCG-WKS-014 isolated from network	EDR response action	Host containment
2026-06-24 11:21:50 EDT	Simulated IOCs blocked at email, DNS, proxy, and EDR controls	Control change log	Infrastructure containment
2026-06-24 14:35:18 EDT	Endpoint reimaged and returned after validation	IT recovery log	Recovery completed
2026-06-25 10:00:00 EDT	Lessons learned review completed	IR review notes	Improvement actions assigned

Table 4: Simulated incident timeline

Diagram 1 is stored at [diagrams/incident_timeline.mmd](#).

6. Initial Detection

The initial detection came from a SIEM correlation rule that combined endpoint process telemetry, PowerShell logging, DNS/proxy activity, and credential access behavior. The alert did not rely on a single indicator; it correlated multiple suspicious behaviors within a short time window.

Detection item	Simulated evidence	Why it mattered
Office child process	EXCEL.EXE spawned powershell.exe	Office-to-PowerShell is a common malware execution pattern
Encoded command line	PowerShell launched with encoded parameter	Obfuscation increased suspicion
External connection	Domain SIMULATED: updates-careportal.example	Not part of normal business traffic
Credential access behavior	LSASS access attempt	Possible credential dumping
Failed lateral movement	SMB logon failures to file server	Possible movement attempt after initial execution

Table 5: Initial detection evidence

Alert name: SIMULATED: Office Spawned PowerShell With Credential Access Behavior

Severity: High

Disposition: True positive in simulated environment

Detection confidence: High

Reason for escalation: PowerShell execution and credential access behavior occurred on the same endpoint within three minutes of attachment execution.

7. Email Analysis

The phishing email was modeled as a healthcare billing-themed lure sent to an employee in the finance workflow. The sender, message headers, domains, and attachment hash below are simulated.

Field	Simulated value
Sender display name	SIMULATED: CarePortal Billing Support
Sender address	SIMULATED: billing-support@careportal-update.example
Recipient	SIMULATED: emiller@northstar-care.example
Subject	SIMULATED: Updated Q2 Patient Billing Adjustment Sheet
Attachment	SIMULATED: Q2_Patient_Billing_Adjustments.xlsm
Attachment SHA256	SIMULATED: 7c9f1e0b0a1c2d3e4f5061728394a5b6c7d8e9f00112233445566778899aabbcc
Sending IP	SIMULATED: 203.0.113.44
Reply-to	SIMULATED: support@careportal-update.example

Table 6: Simulated phishing email summary

Key findings:

- The sender domain was lookalike infrastructure and not associated with the fictional healthcare organization.
- The attachment used a macro-enabled spreadsheet extension.

- The subject line matched business-relevant healthcare billing work, increasing the chance of user interaction.
- The email bypassed modeled quarantine because the attachment was not yet known by hash at delivery time.

Simulated email header details are stored at [assets/simulated_email_header.txt](#).

8. PowerShell Analysis

PowerShell activity began shortly after the attachment opened. The command line was intentionally not reproduced in a weaponized form. The evidence below is sanitized and simulated.

Event	Simulated detail	Assessment
Parent process	EXCEL.EXE	Suspicious parent for PowerShell in this user workflow
Child process	powershell.exe	Execution interpreter
Window style	Hidden	Evasion indicator
Script logging	PowerShell Event ID 4104 generated	Script block captured for review
Network destination	SIMULATED: updates-careportal.example	Simulated command retrieval endpoint
Defender action	Blocked suspicious script content	Execution interrupted

Table 7: Simulated PowerShell analysis

The script attempted to retrieve additional content, stage a credential access routine, and test connectivity to internal file services. The modeled EDR blocked the credential theft routine and prevented the process from completing the lateral movement stage.

Relevant simulated PowerShell evidence is stored at [assets/simulated_powershell_events.csv](#).

9. Windows Event Review

The Windows event review focused on process creation, PowerShell script logging, credential access indicators, logon failures, and remote service activity. The event IDs are realistic examples, but all event contents are simulated for this project.

Event source	Event ID	Simulated host	What was observed	Assessment
Sysmon	1	SIMULATED: NCG-WKS-014	Excel launched PowerShell	Execution
PowerShell	4104	SIMULATED: NCG-WKS-014	Suspicious script block logged	Script analysis
Sysmon	3	SIMULATED: NCG-WKS-014	Network connection to simulated external domain	Command retrieval attempt
Sysmon	10	SIMULATED: NCG-WKS-014	Suspicious process access toward LSASS	Credential theft attempt
Security	4625	SIMULATED: NCG-FS-02	Failed SMB logon attempts	Lateral movement attempt
Security	5140	SIMULATED: NCG-FS-02	Network share access attempt	Scoping evidence
Defender	1116	SIMULATED: NCG-WKS-014	Malware or suspicious script detected	Prevention event
System	7045	SIMULATED: NCG-FS-02	No unauthorized service installation observed	Lateral execution not successful

Table 8: Simulated Windows event review

Important review results:

- No successful interactive logon was observed from the affected endpoint to the file server.
- No domain controller compromise was observed.
- No unauthorized service creation was confirmed on the file server.
- No encryption, ransom note creation, mass file rename activity, or abnormal backup deletion was observed.

Simulated Windows event extracts are stored at [assets/simulated_windows_events.csv](#).

10. MITRE ATT&CK Mapping

Tactic	Technique	Name	Reason
Initial Access	T1566.001	Phishing: Spearphishing Attachment	The simulated attacker delivered a malicious attachment by email.
Execution	T1204.002	User Execution: Malicious File	The simulated user opened the malicious spreadsheet.
Execution	T1059.001	Command and Scripting Interpreter: PowerShell	PowerShell executed after the attachment opened.
Defense Evasion	T1027	Obfuscated Files or Information	The PowerShell command line used encoded content.
Command and Control	T1105	Ingress Tool Transfer	PowerShell attempted to retrieve additional content from simulated external infrastructure.
Credential Access	T1003	OS Credential Dumping	The simulated attacker attempted credential theft behavior.
Credential Access	T1003.001	OS Credential Dumping: LSASS Memory	Telemetry showed suspicious LSASS access behavior.
Lateral Movement	T1021.002	Remote Services: SMB/Windows Admin Shares	Failed SMB logons indicated attempted lateral movement.

Table 9: MITRE ATT&CK mapping

No MITRE ATT&CK impact technique for ransomware is mapped as observed because ransomware deployment did not occur in this scenario.

Diagram 4 is stored at [diagrams/mitre_attack_flow.mmd](#).

11. Simulated Indicators of Compromise

All indicators in this table are simulated for portfolio demonstration. They should not be treated as real threat intelligence.

Type	Simulated indicator	Context
Domain	SIMULATED: careportal-update.example	Lookalike sender domain
Domain	SIMULATED: updates-careportal.example	Simulated PowerShell network destination
IP address	SIMULATED: 203.0.113.44	Simulated sender infrastructure
IP address	SIMULATED: 198.51.100.27	Simulated command retrieval endpoint
Email address	SIMULATED: billing-support@careportal-update.example	Phishing sender
File name	SIMULATED: Q2_Patient_Billing_Adjustments.xlsm	Malicious attachment
SHA256	SIMULATED: 7c9f1e0b0a1c2d3e4f5061728394a5b6c7d8e9f00112233445566778899aabbcc	Simulated attachment hash
Hostname	SIMULATED: NCG-WKS-014	Affected workstation
Username	SIMULATED: ncare\emiller	Affected user
Process	SIMULATED: EXCEL.EXE -> powershell.exe	Suspicious process chain

Table 10: Simulated indicators of compromise

The IOC list is also stored at [assets/simulated_ioc_list.csv](#).

12. Scope of Impact

Scope area	Result	Evidence basis
Affected users	1 simulated user confirmed	Email and EDR logs
Affected endpoints	1 simulated workstation confirmed	EDR process telemetry
Servers compromised	None confirmed	Windows event review
Domain controller compromise	Not observed	Authentication and endpoint telemetry
Data exfiltration	Not observed	Proxy, DNS, and file server review
Ransomware deployment	Not observed	Endpoint, file server, and backup review
Patient data exposure	Not observed in scenario	Simulated file and EHR access review

Table 11: Scope of impact

The investigation found attempted credential theft and attempted lateral movement, but no evidence of successful server compromise, broad credential compromise, data exfiltration, or ransomware deployment.

13. Root Cause Analysis

Root cause area	Finding	Impact
Email filtering	First-seen attachment was delivered to the inbox	User had the opportunity to open the file
User execution	Employee opened a business-relevant attachment	Initial execution occurred
Office hardening	Office child process restrictions were not fully enforced	Excel was able to launch PowerShell
PowerShell controls	Constrained Language Mode and stricter script control were not enforced on the endpoint	Malicious script activity started
Detection coverage	Detection was effective after execution began	Response contained the incident before ransomware

Table 12: Root cause analysis

The primary root cause was a successful phishing lure combined with insufficient Office-to-script interpreter restrictions. Detection and response controls worked, but prevention controls should be strengthened to reduce the chance of execution after attachment delivery.

14. Containment Actions

Time	Containment action	Owner type	Result
2026-06-24 09:28 EDT	Escalated incident to IR queue	SOC analyst	Investigation started
2026-06-24 09:42 EDT	Revoked active sessions for <code>SIMULATED: ncare\emiller</code>	Identity administrator	Account misuse risk reduced
2026-06-24 09:47 EDT	Forced password reset for affected user	Identity administrator	Credentials rotated
2026-06-24 10:04 EDT	Isolated <code>SIMULATED: NCG-WKS-014</code> using EDR	SOC analyst	Host contained
2026-06-24 10:18 EDT	Blocked simulated domains and IPs	Network/security administrator	External callback path blocked
2026-06-24 10:33 EDT	Quarantined matching emails	Messaging administrator	Further user execution reduced

Table 13: Containment actions

Diagram 3 is stored at [diagrams/containment_workflow.mmd](#).

15. Eradication Actions

Action	Detail	Validation
Removed malicious attachment	Quarantined message and attachment across modeled mailboxes	Search showed no remaining matching messages
Removed suspicious scripts	Cleared staged script artifacts from isolated endpoint image	EDR scan clean after removal
Reimaged endpoint	Rebuilt SIMULATED: NCG-WKS-014 from known-good image	Baseline validation passed
Rotated user credentials	Reset affected user's password and revoked tokens	No further failed movement attempts
Blocked simulated IOCs	Added email, DNS, proxy, and EDR blocks	Controls confirmed in logs
Reviewed persistence	Checked startup paths, scheduled tasks, services, registry run keys, and WMI persistence locations	No persistence confirmed

Table 14: Eradication actions

The eradication approach favored reimaging the affected workstation over attempting to clean the endpoint in place. This reduced uncertainty and supported faster return to a trusted baseline.

16. Recovery Actions

Recovery action	Result
Restored user access after password reset and manager validation	Completed
Reissued workstation from clean image	Completed
Validated endpoint health with EDR scan	Completed
Reviewed file server access after containment	No unauthorized access confirmed
Confirmed no ransomware indicators	No encryption, ransom note, or mass rename activity observed
Monitored for recurring IOCs for 48 hours	No recurrence observed in simulated review

Table 15: Recovery actions

Recovery was completed without restoring from backup because ransomware was not deployed and no production data destruction occurred in the modeled incident.

17. Lessons Learned

Lesson	Improvement action
Business-themed lures can bypass user suspicion	Increase role-based phishing training for finance and healthcare billing workflows
Office-to-PowerShell execution is high risk	Enforce attack surface reduction rules and application control
First-seen attachments create exposure	Use attachment detonation and delayed delivery where risk is elevated
Credential theft attempts require fast containment	Prioritize LSASS access alerts for immediate response
Lateral movement attempts should trigger automatic scoping	Add SIEM correlation for endpoint execution plus SMB failures

Table 16: Lessons learned

18. Recommendations

Priority	Recommendation	Framework alignment	Owner type	Target timeline
1	Block Office applications from creating child processes where business workflows allow	NIST CSF PR.PS , DE.CM	Endpoint administrator	7 days
2	Enforce PowerShell logging, script block logging, and controlled execution policy	NIST CSF PR.PS , DE.CM	Endpoint administrator	14 days
3	Add SIEM correlation for Office child process plus external callback plus LSASS access	NIST CSF DE.AE , DE.CM	Detection engineer	14 days
4	Expand attachment sandboxing for macro-enabled documents	NIST CSF PR.DS , DE.CM	Messaging administrator	30 days
5	Review local administrator rights and remove unnecessary privileges	NIST CSF PR.AA	Identity administrator	30 days
6	Validate endpoint isolation and account revocation playbooks quarterly	NIST CSF RS.MA , RS.MI	SOC manager	30 days
7	Conduct a tabletop exercise using this scenario	NIST SP 800-61 Rev. 3, NIST CSF RS.CO	Incident response lead	45 days
8	Confirm backup immutability and recovery testing for file services	NIST CSF RC.RP	IT operations	60 days

Table 17: Recommendations

19. Executive Summary for Leadership

This simulated incident shows that a phishing email can still create real operational risk even when the attacker does not reach the ransomware stage. One employee opened a malicious attachment, which launched suspicious PowerShell activity and attempted to access credential material.

The security team detected the behavior quickly, contained the endpoint, reset the affected user’s access, blocked the simulated attacker infrastructure, and confirmed that ransomware was not deployed. The modeled organization avoided material impact because detection and response actions interrupted the attack before successful lateral movement.

Leadership should treat this as a high-priority control improvement opportunity. The most important actions are to prevent Office from launching script interpreters, strengthen attachment detonation, tune detections for credential theft behavior, and rehearse rapid containment procedures.

20. References

The references used for this portfolio report are listed in [REFERENCES.md](#). Key sources include MITRE ATT&CK Enterprise, NIST Cybersecurity Framework 2.0, and NIST SP 800-61 Rev. 3.

Appendix A: Diagram Index

Diagram	File	Description
Diagram 1	diagrams/incident_timeline.mmd	Simulated event timeline
Diagram 2	diagrams/attack_chain.mmd	Phishing-to-response attack chain
Diagram 3	diagrams/containment_workflow.mmd	SOC containment workflow
Diagram 4	diagrams/mitre_attack_flow.mmd	MITRE ATT&CK technique flow

Appendix B: Report Footer

Portfolio Demonstration | No real client data or credentials included | Version v1.0